

02 Broken Object Level Authorization

Broken Object Level Authorization (BOLA) is the top risk listed in the OWASP API Security Top 10 because when an API takes an object identifier—for instance, an order or user ID and either returns it or modifies it, it fails first to check that the individual making the request is authorized to access it.

An attacker might alter the ID in the request to view or modify other users' data.

To prevent BOLA, developers should run ownership checks on every request, restrict database queries to the authenticated user, centralize authorization logic, and specifically test for cross-user access.